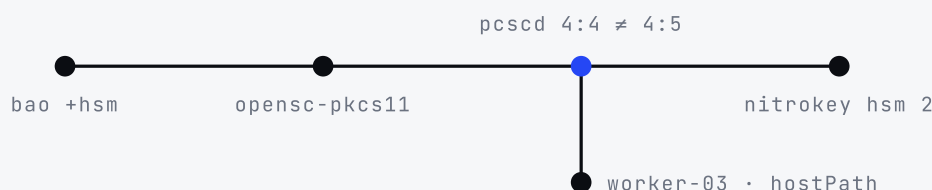


AUTO- UNSEAL OPENBAO

seal "pkcs11" with a USB HSM on the worker: a custom image, the migration from Shamir – and six errors, each of which hid the next.



Auto-Unseal with a Nitrokey HSM 2

seal “pkcs11” for the cluster OpenBao: the USB stick on the worker, a custom image, the migration from Shamir – and six errors, each of which hid the next

Thomas Zachmann

21 September 2026

Contents

What this is about

- How this guide came about

- License and liability

- A word about the values in this guide

- Who this is for

- The building blocks

- The architecture in one picture

Part I – Seal, HSM, PKCS#11: the terms

- What a seal is

- What an HSM adds

- PKCS#11 – the language

- DKEK – the question to ask before the first key

Part II – The stick: Nitrokey HSM 2 on the worker

- USB passthrough in Proxmox

- Packages, pcscd, Polkit

- Initialising the token – with DKEK

- What the token can do – and what not

- Generating the seal key

- The first probe from a pod

Part III – The image

- Why a custom image

- The Dockerfile

- Building and pushing multi-arch

- Trivy

- The protocol problem

- The label problem

Part IV – The chart

- The values

- The Secret with the PIN

- The trap with auditStorage

- The debug pod

Part V – The migration

- Before: snapshot

- Deploy and restart

- `unseal -migrate`

- The proof

- The way back (not carried out)

Part VI – What went wrong, and why

Part VII – Operations and failure behaviour

What can fail now

Recovery keys: what they can and cannot do

They are the old keys – and why to rotate them now

The key is not backed up

Snapshots remain mandatory

Checking that it runs

Part VIII – Debug: the network HSM does not answer

The lab

The chain

Step 1 – Can you get there at all?

Step 2 – Is the library there, and does it load?

Step 3 – Does the library see a slot?

Step 4 – Can the token do what OpenBao needs?

Step 5 – Login and key

Step 6 – One operation

Step 7 – What the HSM itself says

Step 8 – Hold the stanza against what you found

Step 9 – Mounts and Secrets

Step 10 – Now the OpenBao logs

Step 11 – From the node yes, from the pod no

Step 12 – strace, and what it does not show this time

Proven on the side: recovery keys open after a manual seal

The order, as a table

What the lab does not prove

Part IX – One HSM for all pods: the HSM VM (draft)

Way A – Transit seal via the VM OpenBao (recommended)

Way B – p11-kit remote: the PKCS#11 library over the network

Way C – USB/IP

Way D – Nitrokey NetHSM

Recommendation

Part X – OpenBao 2.7: from HSM build to KMS plugin (draft)

The stumbling blocks already visible

Appendix A – All commands

Appendix B – Glossary

About the author

What this is about

N° 1 ended with a ritual: after every pod restart, somebody types three of five unseal keys into `bao operator unseal`. Until then OpenBao is there, but dead – 0/1 READY, no secret comes out, every application waiting for it keeps waiting. A node update at three in the morning means somebody gets up at three in the morning.

This guide abolishes the ritual. The root key, which the Shamir keys used to reconstruct, is afterwards encrypted with a key that never leaves a **Nitrokey HSM 2** – a USB stick plugged into the cluster worker. OpenBao starts, asks the HSM, is unsealed. No human, no file with keys, no cloud KMS.

The way there was longer than planned. The prepared plan (N° 6 in its first draft) called for an AES key on the HSM and the stick on the VM from N° 3. Neither held: the Nitrokey HSM 2 cannot do AES-GCM, and the stick ended up on the Kubernetes worker. The official OpenBao image cannot do PKCS#11. The PKCS#11 library in the custom image spoke a protocol the daemon on the host rejects. The token had a different name than the test tool claimed. And an empty Secret looked like a full one. Six errors, each trivial on its own, together an afternoon – and the actual content of this guide.

It is the sixth part of a series. It assumes the cluster OpenBao from N° 1 and the snapshot from N° 7, without which one should not start a seal migration. Part VIII changes the device: a network HSM – Nitrokey's NetHSM as a test container – is set up in the cluster and broken layer by layer, as a debug procedure with real output. Two parts at the end are drafts and marked as such: an HSM that does not hang off one worker but serves all pods – and the path OpenBao 2.7 prescribes once it discontinues the HSM distribution.

How this guide came about

The other notes in this series were written without AI assistance. This one was not: the rebuild on the cluster ran as a pair-programming session with Claude Code, which contributed research, debugging pods and the first draft of the text. Every command was executed on the cluster, every output is real, every decision was mine. The yardstick stays the same: whoever has worked through this guide can draw, on a blank sheet of paper, the chain from the bao process to the chip in the stick and say at which four points it can break.

License and liability

This guide is published under CC BY 4.0: it may be copied, shared and adapted, commercially too, as long as the author is credited. It is provided without warranty. Everything in it was carried out in a development environment; whoever reproduces it elsewhere does so at their own risk. Running an HSM in production takes more than what is written here – Part VII says what.

A word about the values in this guide

The HSM's user PIN, the SO PIN, the unseal keys and the root token appear nowhere – not even as development values. The PIN went into a Kubernetes Secret as a file, and the file into `rm -P` afterwards. Internal addresses, the external hostname and the stick's serial number are replaced by placeholders (`<worker-03-ip>`, `openbao.example.internal`, `DENK0000000`). The image `softxpert/openbao-pkcs11` is public and real.

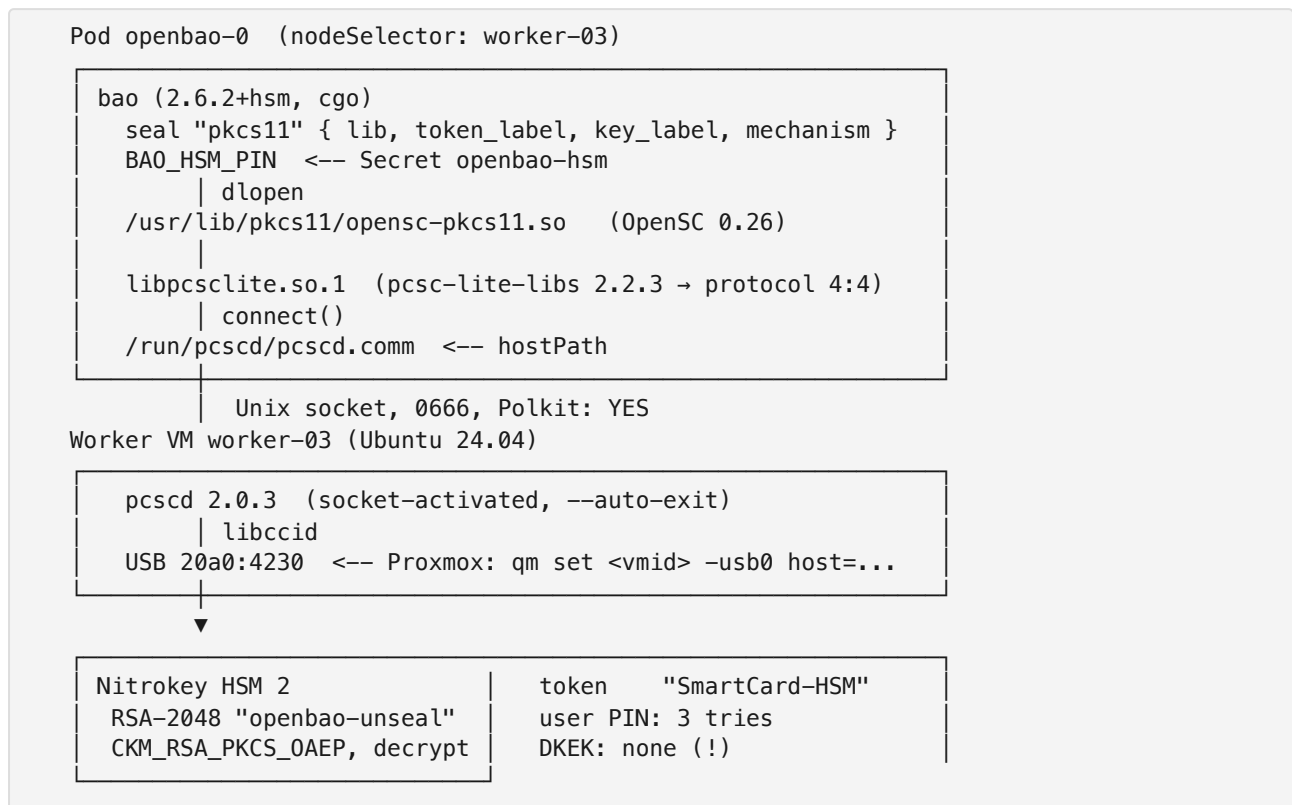
Who this is for

For readers who know N° 1 and have never held an HSM. Part I explains what a seal is, what an HSM adds to it, and what the terms PKCS#11, token, slot, SO PIN and DKEK mean – whoever knows that skips it. OpenBao fundamentals are in my book **Vault in Practice** (Leanpub, leanpub.com/vault-in-practice).

The building blocks

Building block	Version	Role
OpenBao in the cluster (N° 1)	2.6.2, chart 0.29.4, standalone, Raft	the thing to be unsealed
Nitrokey HSM 2	firmware 4.1 (SmartCard-HSM)	holds the seal key <code>openbao-unseal</code> , RSA 2048
Proxmox	–	passes the USB stick to the worker VM via <code>qm set -usb0</code>
Worker VM <code>worker-03</code>	Ubuntu 24.04, <code>pcscd</code> 2.0.3, <code>libccid</code> , OpenSC 0.25	talks to the stick; <code>pcscd</code> listens on <code>/run/pcscd/pcscd.comm</code>
Image <code>softxpert/openbao-pkcs11:2.6.2</code>	<code>openbao/openbao-hsm:2.6.2</code> + OpenSC 0.26 + <code>pcsc-lite-libs 2.2.3</code>	OpenBao with PKCS#11 support and the client library
Helm values	<code>server.image</code> , <code>nodeSelector</code> , <code>hostPath /run/pcscd</code> , <code>seal "pkcs11"</code> , <code>extraSecretEnvironmentVars</code>	ties it all together
Secret <code>openbao-hsm</code>	<code>BA0_HSM_PIN</code> , 8 bytes	the user PIN, only in the cluster

The architecture in one picture



Three things to take away from the picture:

- 1. The chain has four interfaces, and each has its own failure mode.** `bao` ↔ library (build without PKCS#11), library ↔ daemon (protocol version), daemon ↔ reader (Polkit, CCID), reader ↔ chip (PIN, label, key). Part VI has an entry for each.
- 2. The pod is bound to the worker.** A USB stick follows no pod. If worker-03 dies there is no unseal – not with recovery keys, not with anything. That is a deliberate single point of failure, not an oversight, and Part IX shows how to get rid of it.
- 3. The key is not backed up.** The token was initialised without a DKEK. The seal key exists exactly once, in the chip. Part VII says what that means and what has to happen before production use.

Part I – Seal, HSM, PKCS#11: the terms

What a seal is

OpenBao encrypts everything it stores with a **root key** (older texts say master key). The root key itself lies in storage – encrypted. With what, that is what the **seal** decides:

- **Shamir** (N° 1): the root key is split into five parts using Shamir's Secret Sharing, three suffice to reconstruct it. The parts are the unseal keys. After every start, three of them must be entered; only then can OpenBao form the root key and open the barrier.
- **Auto seal**: the root key is encrypted with a key that lives outside OpenBao – in a cloud KMS, in a second OpenBao (transit) or in an HSM. OpenBao asks that system at start, gets the root key back decrypted and opens itself.

With an auto seal the five keys remain, but are called **recovery keys** and do something else: they authorise a root token reset and the way back to Shamir. They **cannot** reconstruct the root key. Whoever loses their HSM has, with recovery keys, a safe without a key.

What an HSM adds

A **hardware security module** is a device that generates, stores and uses cryptographic keys without ever handing them out. You send it data, it answers with the result – signed, decrypted, wrapped. The private key does not leave the chip; making a copy is not provided for, and reading it out is meant to fail physically too.

The Nitrokey HSM 2 is the small form of that: a USB stick with a SmartCard-HSM card from CardContact. It does what a rack HSM does, slowly and for one set of keys. For a seal key that is enough – OpenBao needs the HSM only at start and every ten minutes for a health check.

PKCS#11 – the language

PKCS#11 (also “Cryptoki”) is the standard API through which programs talk to HSMs and smartcards. It is a C library – a .so file – that a program loads via dlopen. The terms in it:

- **Slot** – a socket, physical or logical. Here: the USB reader.
- **Token** – the card in the slot. It has a **label** (a name), a serial number and flags (“login required”, “PIN initialized”).
- **Objects** – what lies on the token: keys, certificates, data. Every object has a label and an ID. Private keys are only visible after login.
- **Mechanisms** – what the token can compute: CKM_RSA_PKCS_OAEP, CKM_AES_GCM, ... Every token can do a different selection. What it cannot do, OpenBao cannot do with it.
- **User PIN** – the login for key operations. Three failed attempts, then it is locked.
- **SO PIN** (security officer) – the administrative login: initialise the token, reset the user PIN, wipe the token. 15 attempts. OpenBao never gets to see it.

For the Nitrokey HSM 2, **OpenSC** provides the PKCS#11 library (`opensc-pkcs11.so`) and the tools (`pkcs11-tool`, `sc-hsm-tool`, `opensc-tool`). OpenSC does not talk to USB itself but to the **PC/SC daemon** `pcscd` over a Unix socket; `pcscd` talks to the reader via the **CCID** driver. Four layers, all of them have to fit.

DKEK – the question to ask before the first key

An HSM does not hand out keys. What if it breaks? The SmartCard-HSM has the **Device Key Encryption Key** for that: if the token is initialised with one or more DKEK shares, keys can later be exported encrypted with the DKEK (`sc-hsm-tool --wrap-key`) and imported onto a second stick initialised with the same shares. Without DKEK: no export, no replacement stick, no backup. The decision is made at `--initialize` and can only be changed afterwards by re-initialising – which wipes all keys.

The token in this guide was initialised **without** DKEK. What that means is in Part VII. Whoever rebuilds this should do it differently, and Part II shows how.

Part II – The stick: Nitrokey HSM 2 on the worker

USB passthrough in Proxmox

The workers are VMs. The stick sits in the Proxmox host and has to be passed to the VM – once, on the host, before anything happens on the VM:

```
# on the Proxmox host
lsusb | grep -i nitrokey
#   Bus 001 Device 005: ID 20a0:4230 Clay Logic Nitrokey HSM

# bind it to the VM – by vendor:product, not by bus/port: survives
# re-plugging into another port
qm set <vmid> -usb0 host=20a0:4230

# a cold boot is the reliable way; hot-plug works on recent QEMU but is
# not worth the uncertainty for an HSM
qm shutdown <vmid> && qm start <vmid>
```

In the VM:

```
$ lsusb | grep -i nitrokey
Bus 002 Device 002: ID 20a0:4230 Clay Logic Nitrokey HSM
```

Packages, pcscd, Polkit

```
sudo apt install -y pcscd libccid pcsc-tools opensc
sudo systemctl enable --now pcscd
```

Ubuntu 24.04 ships pcscd 2.0.3, libccid 1.5.5, OpenSC 0.25. pcscd is **socket-activated**: pcscd.socket listens on /run/pcscd/pcscd.comm, the service starts with the first client and exits again after idling (--auto-exit). systemctl is-active pcscd therefore often shows inactive while pcscd.socket is active – that is not an error.

```
$ pcsc_scan
Reader 0: Nitrokey Nitrokey HSM (DENK00000000 ) 00 00
Card state: Card inserted,
ATR: 3B DE 18 FF 81 91 FE 1F C3 80 31 81 54 48 53 4D 31 73 80 21 40 81 07 FA
```

Whoever is not root sees nothing at first: pcscd asks **Polkit** whether the requesting process may use the reader, and the default says no to everything that does not sit in a local session. A container process sits in none. The rule that opens it:

```
// /etc/polkit-1/rules.d/40-allow-pcsd.rules
polkit.addRule(function(action, subject) {
    if (
        action.id == "org.debian.pcsd-lite.access_pcsd" ||
        action.id == "org.debian.pcsd-lite.access_card"
    ) {
        return polkit.Result.YES;
    }
});
```

```
sudo systemctl restart polkit pcsd
```

That is deliberately coarse: every process on the host may reach the reader. Justifiable on a worker that only runs pods anyway; on a multi-user machine one would check `subject.user`. The socket itself is `0666` (`srw-rw-rw-`); the actual access control is Polkit.

Initialising the token – with DKEK

A factory-fresh stick has a transport SO PIN (3537363231383830) and has to be initialised. Three decisions are made in the process: SO PIN, user PIN, DKEK shares. **This is the step that went differently in this guide than it should have** – the token was initialised without DKEK shares. This is what it would look like done right:

```
# SO PIN: 16 hex characters. User PIN: 6–15 characters. Both are prompted,
# not passed as arguments (shell history!).
sc-hsm-tool --initialize --dkek-shares 1 --label openbao

# create and import the DKEK share – the share file is the HSM's backup.
# It is password-protected; keep file and password apart.
sc-hsm-tool --create-dkek-share dkek-share-1.pbe
sc-hsm-tool --import-dkek-share dkek-share-1.pbe

sc-hsm-tool                                # must show "DKEK shares : 1"
```

With a DKEK, every key generated later can be exported as an encrypted file (`--wrap-key`) and imported onto a replacement stick initialised with the same share file. Without DKEK there is no replacement stick.

The state here:

```
$ sc-hsm-tool
Using reader with a card: Nitrokey Nitrokey HSM (DENK00000000 ) 00 00
Version                : 4.1
Config options         :
    User PIN reset with SO-PIN enabled
SO-PIN tries left      : 15
User PIN tries left    : 3
```

No line DKEK shares. What lies on this token lies only there.

What the token can do – and what not

Before generating a key, ask which mechanisms the token supports. For the seal, OpenBao needs an AEAD scheme: CKM_AES_GCM or CKM_RSA_PKCS_OAEP.

```
$ pkcs11-tool -M | grep -E 'AES|OAEP'
RSA-PKCS-OAEP, keySize={1024,4096}, hw, decrypt
```

No AES-GCM. The prepared plan – AES-256, mechanism = "0x1087" – would have failed at the token. RSA-OAEP is there, with decrypt in hardware. This is how the seal works then: OpenBao generates a random AES key, encrypts the root key with it, wraps the AES key with the public RSA key (in software) and stores both. On unseal it sends the wrapped AES key to the HSM, which decrypts it with the private RSA key. The private key stays in the chip.

Generating the seal key

An RSA-2048 pair, label openbao-unseal, ID 10, usage decrypt:

```
pkcs11-tool --login --keypairgen --key-type rsa:2048 \
--label openbao-unseal --id 10 --usage-decrypt
```

The user PIN is prompted. Afterwards – without login one only sees the public part, that is intended:

```
$ pkcs11-tool -0
Using slot 0 with a present token (0x0)
Public Key Object; RSA 2048 bits
label:      openbao-unseal
ID:         10
Usage:      encrypt, verify, wrap
```

(The key in this guide was generated before the recorded session; the command above is the standard procedure that leads to exactly this object.)

The first probe from a pod

Before OpenBao enters the picture: does a container see the stick? A throwaway pod on worker-03 with the pcscd socket as hostPath:

```

apiVersion: v1
kind: Pod
metadata: {name: pkcs11-test, namespace: openbao}
spec:
  nodeSelector: {kubernetes.io/hostname: worker-03}
  securityContext: {runAsNonRoot: true, runAsUser: 1000, runAsGroup: 1000}
  containers:
  - name: test
    image: debian:bookworm-slim          # later: custom image with opensc
    command: ["sleep", "infinity"]
    volumeMounts: [{name: pcscd, mountPath: /run/pcscd}]
  volumes:
  - name: pcscd
    hostPath: {path: /run/pcscd, type: Directory}

```

```

$ kubectl exec -n openbao pkcs11-test -- pkcs11-tool -L
Available slots:
Slot 0 (0x0): Nitrokey Nitrokey HSM (DENK00000000 ) 00 00
  token label      : SmartCard-HSM (UserPIN)
  token manufacturer : www.CardContact.de
  token model      : PKCS#15 emulated
  token flags      : login required, rng, token initialized, PIN initialized

```

Works – as UID 1000, from Debian bookworm, with OpenSC 0.23. This result later produced two false certainties: that the chain pod → socket → pcscd works in principle (true), and that the token is called SmartCard-HSM (UserPIN) (true only for this OpenSC version).

Part III – The image

Why a custom image

The official openbao/openbao contains no OpenSC and – more importantly – a bao binary compiled without PKCS#11 support. The seal needs CGO and the build tag hsm. OpenBao ships a second distribution for that: openbao/openbao-hsm (Alpine) and openbao/openbao-hsm-ubi (RHEL UBI, glibc). Both on Docker Hub and Quay, amd64 and arm64.

The first attempt took the wrong base. The Dockerfile was formally correct, the image built, the pod started – and died:

```
Error configuring seal "pkcs11": this build of OpenBao has PKCS#11 disabled
```

The libraries were there. The program that was supposed to load them could not. The message is unambiguous once you know there are two builds.

The Dockerfile

```
FROM openbao/openbao-hsm:2.6.2

USER root

# pcsc-lite-libs is pinned to 2.2.x from Alpine 3.21 on purpose: pcsc-lite >= 2.3
# speaks client protocol 4:5, but pcsd 2.0.3 on the Ubuntu 24.04 worker only
# accepts 4:4 and rejects newer clients ("Communication protocol mismatch").
# Revisit when the worker's pcsd is upgraded or the base image changes.
RUN apk add --no-cache \
    --repository https://dl-cdn.alpinelinux.org/alpine/v3.21/main \
    opensc \
    'pcsc-lite-libs=2.2.3-r1'

USER openbao
```

Three lines do something, and each has a story:

- FROM openbao/openbao-hsm:2.6.2 – the build with PKCS#11. bao version says OpenBao v2.6.2+hsm ... (cgo). Alpine 3.24, user openbao with UID 100 – the same UID as in the standard image, nothing in the chart has to change.
- opensc – the PKCS#11 library /usr/lib/pkcs11/opensc-pkcs11.so and the tools. Alpine does not pull in pcsc-lite-libs automatically; without the package OpenSC reports “Unable to load external module”.
- pcsc-lite-libs=2.2.3-r1 from the **3.21** repository instead of 2.4.0 from 3.24 – the second error of this guide, explanation follows.

Building and pushing multi-arch

The cluster is amd64, the Mac arm64. `docker build` yields only the host architecture; for both it takes BuildKit:

```
docker buildx build --platform linux/amd64,linux/arm64 \
  -t softxpert/openbao-pkcs11:2.6.2 --push .
```

`--push` is not a convenience here: a multi-arch image is a manifest list pointing to one image per platform. The classic local image store cannot hold such a thing; BuildKit exports straight to the registry. The amd64 part is built on the Mac via QEMU emulation – uncritical for `apk add`.

```
$ docker buildx imagetools inspect softxpert/openbao-pkcs11:2.6.2
Digest:      sha256:265babb4f237b03cbcd94abaaf84a9cb5f75d74acecf88a867685f792564e2c5
Platform:    linux/amd64
Platform:    linux/arm64
```

The digest is the reference that belongs in the values – not the tag. The tag 2.6.2 was overwritten three times in this session (wrong base, right base, pinned library). With `pullPolicy: IfNotPresent` the worker would have kept the cached old copy every time.

Trivy

```
$ trivy image --platform linux/amd64 --severity HIGH,CRITICAL softxpert/openbao-pkcs11:2.6.2
softxpert/openbao-pkcs11:2.6.2 (alpine 3.24.1)  2 HIGH  (libcrypto3/libssl3, OpenSSL QUI
C DoS, fixed in 3.5.8-r0)
usr/bin/bao (gobinary)                          9 HIGH
```

All eleven findings come from the base image; `opensc` and `pcsc-lite-libs` added not a single one. Five of the nine in the Go binary are false positives: Trivy reports OpenBao CVEs that, by its own table, are fixed in 2.0.3 to 2.5.4 – but the binary carries a Go pseudo-version (`v0.0.0-20260818...`) instead of `v2.6.2`, and Trivy cannot compare it. The two OpenSSL findings could be fixed with `apk upgrade --no-cache`.

The protocol problem

The image with the right base started, found the PIN – and then:

```
Error configuring seal "pkcs11": failed to find token with label: SmartCard-HSM (UserPIN)
```

The container lived too briefly for a `kubectl exec`. So a debug pod with **the same image, the same UID, the same mounts, the same node**, running only `sleep`:

```
$ kubectl exec -n openbao pkcs11-debug -- opensc-tool -l
No smart card readers found.
```

The same socket at which the Debian test pod had seen the stick minutes before. The answer was in the host's journal:

```
$ sudo journalctl -u pcscd --since -15min
pcscd[530642]: winscard_svc.c:402:ContextThread() Communication protocol mismatch!
pcscd[530642]: winscard_svc.c:404:ContextThread() Client protocol is 4:5
pcscd[530642]: winscard_svc.c:406:ContextThread() Server protocol is 4:4
```

pcsc-lite raised the minor version of its client-server protocol with version 2.3.0, and pcscd rejects clients with a different minor version. Empirically, with throwaway pods from different Alpine versions against the same host:

Alpine	pcsc-lite-libs	protocol	against pcscd 2.0.3
3.21	2.2.3	4:4	✓ token visible
3.22	2.3.3	4:5	✗ "No smart card readers"
3.24	2.4.0	4:5	✗
Debian bookworm	1.9.9	4:4	✓ (the test pod)

Ubuntu 24.04 stays on pcscd 2.0.3 – the host cannot be lifted without third-party packages. The client side can be: one line in the Dockerfile. That is a cross-release package and deserves a comment, so that at the next base image change somebody checks whether it is still needed.

The label problem

With the pinned library, from the debug pod:

```
$ kubectl exec -n openbao pkcs11-debug -- pkcs11-tool -L
Slot 0 (0x0): Nitrokey Nitrokey HSM (DENK00000000) 00 00
token label      : SmartCard-HSM
```

Not SmartCard-HSM (UserPIN). The label is not an attribute of the chip but is generated by OpenSC's PKCS#15 emulation – and OpenSC 0.26 generates a different one than 0.23 and 0.25. `token_label` in the seal stanza has to be what **the OpenSC version in the image** reports. Check after every rebuild. The alternative `slot = "0"` is stable with a single reader, but less readable.

Part IV – The chart

The values

The changes to helm/values.yaml from N° 1, everything under server::

```
server:
  # chart default registry is quay.io – without "registry",
  # quay.io/softxpert/openbao-pkcs11 would be pulled: ImagePullBackOff.
  image:
    registry: docker.io
    repository: softxpert/openbao-pkcs11
    tag: "2.6.2@sha256:265babb4f237b03cbcd94abaaf84a9cb5f75d74acecf88a867685f792564e2c5"
    pullPolicy: IfNotPresent

  # the stick hangs off worker-03. Deliberate SPOF (Part IX).
  nodeSelector:
    kubernetes.io/hostname: worker-03

  # mount the directory, not the socket file: pcscd recreates the socket
  # on every start; a file mount would point at the dead inode.
  # no readOnly – connect() on a unix socket needs write permission.
  volumes:
    - name: pcscd
      hostPath:
        path: /run/pcscd
        type: Directory
  volumeMounts:
    - name: pcscd
      mountPath: /run/pcscd

  standalone:
    enabled: true
    config: |
      ui = true
      listener "tcp" { ... }           # as in N° 1
      storage "raft" { ... }          # as in N° 1

    # token_label is what OpenSC *in this image* reports (pkcs11-tool -L):
    # 0.26 says "SmartCard-HSM", older versions "SmartCard-HSM (UserPIN)".
    seal "pkcs11" {
      lib      = "/usr/lib/pkcs11/opensc-pkcs11.so"
      token_label = "SmartCard-HSM"
      key_label  = "openbao-unseal"
      mechanism  = "CKM_RSA_PKCS_OAEP"
    }

  # the PIN comes from the Secret, never from the file
  extraSecretEnvironmentVars:
    - envName: BAO_HSM_PIN
      secretName: openbao-hsm
      secretKey: BAO_HSM_PIN
```

Four points on that:

- **tag with digest.** The chart renders `registry/repository:tag`; a tag of the form `2.6.2@sha256:...` yields a valid reference in which the digest wins. No new chart parameter needed.
- **pin is not in the stanza.** Every seal parameter has an environment variable (`BA0_HSM_PIN`, `BA0_HSM_LIB`, ...), and the variable takes precedence. The ConfigMap with the stanza lies readable in the cluster; the Secret does not.
- **mechanism is explicit**, although OpenBao could derive it from the key type. The repo should state what the HSM does.
- **updateStrategyType: OnDelete** is the chart default. A `helm upgrade` changes the StatefulSet template but replaces no running pod. Every change here only takes effect with `kubectl delete pod openbao-0`.

The Secret with the PIN

```
# in a separate terminal, zsh:
read -rs "PIN?HSM user PIN: "; printf '%s' "$PIN" > /tmp/hsm-pin; unset PIN
wc -c < /tmp/hsm-pin                # 6-15, otherwise something is wrong

kubectl -n openbao create secret generic openbao-hsm \
  --from-file=BA0_HSM_PIN=/tmp/hsm-pin
rm -P /tmp/hsm-pin                # macOS; Linux: shred -u

# and CHECK – kubectl does not validate values:
kubectl -n openbao get secret openbao-hsm -o json \
  | python3 -c "import sys,json,base64; d=json.load(sys.stdin)['data']; print({k: len(base64.b64decode(v)) for k,v in d.items()})"
{'BA0_HSM_PIN': 8}
```

The last line is not decoration. The first attempt of this guide produced a Secret with **0 bytes**: the instructions said `read -rs -p "Prompt" PIN – bash syntax`. In `zsh`, `read -p` means “read from the coprocess”, `$PIN` stayed empty, `--from-literal=BA0_HSM_PIN=""` created an empty Secret, and OpenBao said `pin` is required. The Secret existed, had the right key, looked like any other in `kubectl get secret`.

The trap with auditStorage

Not part of the seal, but part of this rebuild: the values got an `auditStorage` (its own volume for the audit device). That creates a second `volumeClaimTemplate` in the StatefulSet – and Kubernetes forbids that on an existing StatefulSet:

```
updates to statefulset spec for fields other than 'replicas', 'ordinals',
'template', 'updateStrategy', 'persistentVolumeClaimRetentionPolicy' and
'minReadySeconds' are forbidden
```

`helm --dry-run=server` does **not** see this – it renders with server lookups but does not send the manifests to the API server with `dryRun`. The way: `kubectl delete sts openbao --cascade=orphan` (the pod keeps running), `helm upgrade` creates the StatefulSet anew and adopts the pod via its labels, then `delete pod`. The PVC stays thanks to `persistentVolumeClaimRetentionPolicy: Retain`.

The debug pod

The most important tool of this guide, for the appendix:

```
apiVersion: v1
kind: Pod
metadata: {name: pkcs11-debug, namespace: openbao}
spec:
  nodeSelector: {kubernetes.io/hostname: worker-03}
  restartPolicy: Never
  securityContext: {runAsNonRoot: true, runAsUser: 100, runAsGroup: 1000}
  containers:
  - name: debug
    image: docker.io/softxpert/openbao-pkcs11:2.6.2@sha256:265babb4...
    command: ["sleep", "1800"]
    volumeMounts: [{name: pcscd, mountPath: /run/pcscd}]
  volumes:
  - name: pcscd
    hostPath: {path: /run/pcscd, type: Directory}
```

Same image, same UID 100, same mount, same node – just sleep instead of bao. Inside: `opensc-tool -l, pkcs11-tool -L, -0, -M`. What works here works in OpenBao too; what fails here fails there with a worse error message.

Part V – The migration

Before: snapshot

```
kubectl -n openbao exec -it openbao-0 -- sh -c \  
  'bao login -method=userpass username=snapshot >/dev/null && \  
    bao operator raft snapshot save /tmp/pre-pkcs11.snap'  
kubectl -n openbao cp openbao-0:/tmp/pre-pkcs11.snap ./pre-pkcs11-2026-09-21.snap
```

Non-negotiable, and with a deadline: a snapshot needs an **unsealed** OpenBao. As soon as the pod restarts with the seal stanza it is sealed until the migration is through – the window is closed then. The first run here was aborted for exactly that reason and the snapshot taken afterwards.

Deploy and restart

```
$ helm upgrade openbao openbao/openbao --version 0.29.4 -n openbao -f helm/values.yaml  
Release "openbao" has been upgraded. Happy Helming!  
REVISION: 8  
  
$ kubectl -n openbao delete pod openbao-0  
$ kubectl -n openbao logs openbao-0 | grep -E 'seal|Seal'  
core: entering seal migration mode; Vault will not automatically unseal even  
      if using an autoseal: from_barrier_type=shamir to_barrier_type=pkcs11  
Auto Seal: pkcs11 (builtin: true, key_label: "openbao-unseal",  
             lib: "/usr/lib/pkcs11/opensc-pkcs11.so", mechanism: "CKM_RSA_PKCS_OAEP",  
             token_label: "SmartCard-HSM")  
  
$ kubectl -n openbao exec openbao-0 -- bao status  
Seal Type           pkcs11  
Recovery Seal Type  shamir  
Initialized          true  
Sealed               true  
Total Recovery Shares 5  
Threshold            3  
Seal Migration in Progress true  
Version              2.6.2+hsm
```

OpenBao has found the HSM, recognised the key, accepted the PIN – and knows that the root key in storage is still Shamir-encrypted. It waits.

unseal -migrate

```
kubectl -n openbao exec -it openbao-0 -- bao operator unseal -migrate  
Unseal Key (will be hidden):
```

Three times, one Shamir key each. On the third the work happens:

```
core: migrating from shamir to auto-unseal: to=pkcs11
core: seal migration complete
core: post-unseal setup complete
```

```
$ bao status
Seal Type          pkcs11
Recovery Seal Type shamir
Sealed             false
Total Recovery Shares 5
Threshold          3
```

Seal Migration in Progress is gone. The five keys are now recovery keys. `-migrate` is thereby used up – a second time would be an error (“no migration seal found”, the same message as for a pod that does not have the stanza yet; the first attempt here ran against exactly such a pod).

The proof

Migration successful does not mean auto-unseal works. The test that matters: delete the pod, enter **nothing**.

```
$ kubectl -n openbao delete pod openbao-0
$ kubectl -n openbao logs openbao-0 | grep -E 'unseal'
core: stored unseal keys supported, attempting fetch
core: vault is unsealed
core: unsealed with stored key

$ kubectl -n openbao get pod openbao-0
NAME          READY   STATUS    RESTARTS   AGE
openbao-0     1/1    Running   0          21s

$ curl -s -o /dev/null -w '%{http_code}\n' https://openbao.example.internal/v1/sys/health
200
```

2.4 seconds between attempting `fetch` and `unsealed`. That is the RSA decryption in the stick plus four layers in between.

The way back (not carried out)

Should the HSM be replaced or the seal go back to Shamir: keep the stanza, add `disabled = "true"`, restart the pod, then `bao operator unseal -migrate` – this time with three **recovery** keys. OpenBao decrypts the root key one last time via the HSM and re-encrypts it for Shamir. Prerequisite: the HSM is still there. The way back needs both seals at the same time. That is why a dying HSM has to be acted on immediately – not once it is dead.

This step was not carried out here. It belongs in the restore drill from N° 7, before the seal counts as production.

Part VI – What went wrong, and why

Error	Symptom	Cause	Fix
Wrong base image	this build of OpenBao has PKCS#11 disabled	openbao/openbao is built without CGO/hsm	FROM openbao/openbao-hsm:2.6.2
Empty Secret	pin is required; Secret exists	zsh: read -p reads from the coprocess, \$PIN empty	zsh syntax read -rs "PIN?...", check the length
Protocol mismatch	failed to find token; in the debug pod “No smart card readers”; host journal Client 4:5, Server 4:4	pcsc-lite ≥ 2.3 in the image vs. pcscd 2.0.3 on Ubuntu 24.04	pin pcsc-lite-libs=2.2.3-r1 from Alpine 3.21
Wrong token label	failed to find token with label: SmartCard-HSM (UserPIN)	label comes from OpenSC’s PKCS#15 emulation; 0.26 ≠ 0.23/0.25	read the label from the target image: SmartCard-HSM
No migration seal	can't perform a seal migration, no migration seal found	unseal -migrate against a pod without the stanza (deploy was missing)	order: deploy → pod → -migrate
Immutable STS	helm upgrade would change volumeClaimTemplates	Kubernetes forbids it; --dry-run=server does not check it	delete sts --cascade=orphan, then helm upgrade
Wrong registry prefix (avoided)	would be ImagePullBackOff	chart default registry: quay.io	registry: docker.io explicitly
Stale image (avoided)	would be old image despite push	same tag + IfNotPresent + node cache	digest in tag

And two that had no error message: the prepared plan called for AES-GCM, which the token cannot do – noticed only at `pkcs11-tool -M`. And the token was initialised without DKEK – noticed only while writing this guide, at `sc-hsm-tool`. Both would have been known before the first key if the two commands had been run first.

Part VII – Operations and failure behaviour

What can fail now

Before the rebuild there was one failure mode: pod restarts, somebody types keys. Now there are five, and none is solved by typing:

Fails	Symptom	What helps
worker-03	pod Pending (nodeSelector), Raft PVC stuck	stick into another worker, <code>qm set</code> on the other VM, change nodeSelector, Polkit rule there
USB stick	failed to find token, health-check warnings in the log	replacement stick – only with a DKEK share (see below)
pcscd on the host	same symptom	<code>systemctl restart pcscd.socket</code> ; read the journal
Secret openbao-hsm	pin is required	recreate the Secret, restart the pod
User PIN locked	CKR_PIN_LOCKED	<code>sc-hsm-tool --unlock-pin</code> with the SO PIN

On the last row: the user PIN has **three tries**. A pod in CrashLoop with a wrong PIN in the Secret uses them up in under a minute. After that the token is locked, and only the SO PIN opens it again. Whoever changes the PIN checks the Secret (length check!) before restarting the pod.

OpenBao runs a **seal health check** every ten minutes – encrypts and decrypts a random value via the HSM – and warns in the log when it fails. That is the line a log alert belongs on: it comes hours before the restart that then no longer works.

Recovery keys: what they can and cannot do

- **Can:** generate a new root token (`generate-root`), authorise the way back to Shamir (`unseal – migrate with disabled = "true"`), reopen a manually sealed OpenBao (`bao operator seal`) – but only if the HSM is reachable; they merely authorise then.
- **Cannot:** reconstruct the root key. Without the HSM the data is encrypted, and the recovery keys are paper.

They still belong in the password manager, in the same place as the unseal keys before – and the runbook from N° 1 has to be renamed: after a restart there is nothing to unseal; whoever tries gets an error.

They are the old keys – and why to rotate them now

A misunderstanding I had myself: on a *fresh initialisation* with an HSM seal (`bao operator init` against a new instance), OpenBao generates new recovery keys and prints them once. On a *migration* that does not happen. `unseal -migrate` repurposes the five Shamir keys – the same key material, a new role. `bao status` shows it: Recovery Seal Type shamir, Total Recovery Shares 5, Threshold 3 – the old parameters.

That also means: the keys that were typed into a terminal three times during the migration are the keys that will authorise the way back from now on. Whoever had them on several machines, in a screen share or in a shell history during that session rotates them now – the migration is the natural moment, because the old ones are at hand anyway:

```
kubectl -n openbao exec -it openbao-0 -- bao operator rekey \
  -target=recovery -init -key-shares=5 -key-threshold=3
# output: a nonce. Then three times, one OLD recovery key each:
kubectl -n openbao exec -it openbao-0 -- bao operator rekey -target=recovery -nonce=<nonce
>
```

On the third key OpenBao prints **five new recovery keys** – once, in the terminal. The old ones are invalid from that moment. The new ones go into the password manager before anything else happens (N° 7, the error with the shell variables). `-target=recovery` is the difference to rekeying a Shamir seal; without the flag OpenBao tries to rotate the barrier keys, and an auto seal does not have any.

I did **not** carry out this step here – this instance’s keys have only seen one terminal. It is here as a procedure because it belongs in every runbook that describes a migration.

The key is not backed up

This is the point this guide cannot explain away. The token has no DKEK. `sc-hsm-tool --wrap-key` is therefore impossible; the seal key `openbao-unseal` exists exactly once. If the stick fails there is no replacement – and thus no way to the Raft data, not via the snapshot either, because that is encrypted with the same root key.

For the lab test that is acceptable. Before production use it is not, and the way there is clear:

1. Migrate back to Shamir (Part V, the way back) – while the stick is alive.
2. Re-initialise the token with `--dkek-shares 1`, create the share file, import it, store share and password separately.
3. Generate the key anew, export it (`--wrap-key`), store the export.
4. Migrate to PKCS#11 again. Procure a second stick, initialise it with the same share, import the key, restore drill with it.

That is an afternoon. It is cheaper than the day the stick stops blinking.

Snapshots remain mandatory

Auto-unseal changes nothing about N° 7. The snapshot CronJob keeps running; the restore drill has to know one more detail from now on: an instance that receives the snapshot needs the same seal – the same HSM, or the way back to Shamir before the snapshot. Playing a snapshot of a pkcs11-sealed OpenBao into a Shamir drill instance is rejected.

Checking that it runs

```
kubectl -n openbao get pod openbao-0 -o wide          # 1/1, NODE worker-03
kubectl -n openbao exec openbao-0 -- bao status        # Seal Type pkcs11, Sealed false
kubectl -n openbao logs openbao-0 | grep -i 'health'   # no warnings
ssh worker-03 'sudo journalctl -u pcsd --since -1h | grep -ci mismatch' # 0
ssh worker-03 'sc-hsm-tool | grep tries'              # User PIN tries left: 3
```

Part VIII – Debug: the network HSM does not answer

The stick from Part II hangs off one worker. An HSM reached over the network – Securosys Primus, Thales Luna, Nitrokey NetHSM – hangs off nothing, and that is exactly why more goes wrong with it: between bao and the key there are no longer pcscd and a socket but a **vendor library** that speaks TCP, does TLS, reads its own configuration file and writes its own logs – and in between, a Kubernetes network with DNS, Services and NetworkPolicies.

This part is a session, not theory. Nitrokey ships the NetHSM as a container for testing, and the matching PKCS#11 library comes prebuilt for musl. That makes it possible to set up a network HSM in the cluster and then break it layer by layer. The order in which you check the layers is not negotiable: **from the outside in, from dumb to clever**. Whoever starts with the OpenBao logs reads an error message that originated four layers further down. There are six failures in this part; four of them were not planned.

The lab

Building block	Version	Role
nitrokey/nethsm:testing	S-Keyfender 5.0	software NetHSM, REST API on 8443, amd64 only
nethsm-pkcs11	v3.0.0, musl	the vendor library; reads /etc/nitrokey/p11nethsm.conf
image softxpert/openbao-nethsm:2.6.2	openbao-hsm + library + OpenSC	OpenBao with PKCS#11 and pkcs11-tool
dev cluster	RKE2, 5x amd64, Cilium	the network it happens in

Two things went wrong before the first line of the procedure was due. The NetHSM container only runs on amd64; on the Mac's arm64 kind cluster it started emulated and died with Failure("same data from timer ...") – its entropy self-test gets identical timer values under emulation. So a real amd64 cluster. And the library has **no published checksums**: checksums.txt in the release is a 404. It was checked with file (ELF, architecture) – acceptable for a lab, not for production.

The Dockerfile, analogous to Part III:

```
FROM openbao/openbao-hsm:2.6.2
ARG TARGETARCH
USER root
COPY libnethsm_pkcs11-x86_64.so /tmp/x86_64.so
COPY libnethsm_pkcs11-aarch64.so /tmp/aarch64.so
RUN set -eu; case "$TARGETARCH" in amd64) a=x86_64;; arm64) a=aarch64;; esac; \
  mkdir -p /usr/lib/nitrokey /etc/nitrokey && cp /tmp/$a.so /usr/lib/nitrokey/libnethsm_
pkcs11.so && rm /tmp/*.so && \
  apk add --no-cache opensc pcsc-lite-libs # pkcs11-tool for the debug steps
USER openbao
```

The NetHSM as a Deployment with Service nethsm, a Job that provisions it (operator user operator, RSA-2048 key openbao-unseal with mechanism RSA_Decryption_OAEP_SHA256), the library configuration as a ConfigMap, the operator passphrase as a Secret – all values are lab values and printed on purpose:

```
# /etc/nitrokey/p11nethsm.conf (ConfigMap p11nethsm)
log_level: Info
slots:
  - label: LabHSM
    operator:
      username: "operator"
    instances:
      - url: "https://nethsm.nethsm-lab.svc:8443/api/v1"
        danger_insecure_cert: true
```

```
# excerpt from values-nethsm.yaml
server:
  image: {registry: docker.io, repository: softxpert/openbao-nethsm, tag: "2.6.2@sha256:48c668b6..."}
  volumes:      [{name: p11nethsm, configMap: {name: p11nethsm}}]
  volumeMounts: [{name: p11nethsm, mountPath: /etc/nitrokey, readOnly: true}]
  extraSecretEnvironmentVars:
    - {envName: BAO_HSM_PIN, secretName: openbao-hsm, secretKey: BAO_HSM_PIN}
  standalone:
    config: |
      seal "pkcs11" {
        lib      = "/usr/lib/nitrokey/libnethsm_pkcs11.so"
        token_label = "LabHSM"
        key_label  = "openbao-unseal"
        mechanism  = "CKM_RSA_PKCS_OAEP"
      }
```

All manifests are in cluster/nethsm-lab/.

The chain

Pod openbao-lab-0

```
bao seal "pkcs11" { lib, token_label, key_id, mechanism }
| dlopen
libnethsm_pkcs11.so -- reads --> /etc/nitrokey/p11nethsm.conf
| HTTPS (basic auth: operator / BAO_HSM_PIN)
```

NetworkPolicy · CoreDNS · Service nethsm (endpoints!)

NetHSM :8443 /api/v1/keys/openbao-unseal/decrypt
└─ its own log: every request, every status code

Step 1 – Can you get there at all?

The first start of the OpenBao pod, before anything was broken on purpose:

```
$ kubectl -n nethsm-lab logs openbao-lab-0 | grep nethsm_pkcs11
[INFO nethsm_pkcs11::config::logging] Loaded config file at: /etc/nitrokey/p11nethsm.conf
[INFO nethsm_pkcs11::config::initialization] Loaded configuration with 1 slots
[WARN nethsm_pkcs11::backend::login] Connection attempt 1 failed: IO error connecting to
the instance, io: Connection refused, retrying in 0s
[ERROR nethsm_pkcs11::backend::login] Retry count exceeded after 0 attempts, instance is u
nreachable
[ERROR nethsm_pkcs11::api::token] Error getting info: Api(InstanceRemoved)
Error configuring seal "pkcs11": failed to find token with label: LabHSM
```

Connection refused – seconds after the provisioning job from the same namespace had reached the NetHSM. From the pod, not from the node, with the debug pod from Part IV (same image, same UID, same mount):

```
$ kubectl -n nethsm-lab exec pkcs11-debug -- nslookup nethsm.nethsm-lab.svc
** server can't find nethsm.nethsm-lab.svc: NXDOMAIN
$ kubectl -n nethsm-lab exec pkcs11-debug -- wget -q -O- --no-check-certificate https://ne
thsm:8443/api/v1/health/state
wget: can't connect to remote host (10.43.87.221): Connection refused
```

Two lessons in two lines. First: nslookup in BusyBox queries the name absolutely and knows no search domains – nethsm.nethsm-lab.svc is only a name with .cluster.local. wget resolved it via resolv.conf. Second: the name resolves to the Service IP, and that refuses. A Service refuses when it has **no endpoints**:

```
$ kubectl -n nethsm-lab get pods,endpoints
NAME                                READY    STATUS
pod/nethsm-5844c8b95f-xzw75        0/1     Running
NAME                                ENDPOINTS
endpoints/nethsm                    <none>

$ kubectl -n nethsm-lab logs deploy/nethsm | tail -2
[http.access] request GET /api/v1/health/alive
[http.access] response 412 response time 4.106ms
```

The readiness probe pointed at /api/v1/health/alive – and the NetHSM answers 200 there only while it is *Unprovisioned* or *Locked*. Once it is *Operational*, it answers 412; /health/ready behaves the other way round. The job got through because the pod was still “ready” then; the provisioning itself took the endpoints away. A refused that has nothing to do with firewalls. Fix: a TCP probe that holds in every state.

And one more thing that only showed up on re-checking: wget against the **pod IP** instead of the name fails in the TLS handshake (tlsv1 alert decode error) – the NetHSM wants SNI. So step 1 means: test with the name the library uses.

Step 2 – Is the library there, and does it load?

```
kubectl -n nethsm-lab exec openbao-lab-0 -- ldd /usr/lib/nitrokey/libnethsm_pkcs11.so
kubectl -n nethsm-lab exec openbao-lab-0 -- ls -la /etc/nitrokey/
```

ldd has to resolve every line; a not found is reported by OpenBao as CKR_GENERAL_ERROR without naming the dependency. And the library needs **its** configuration. With the ConfigMap mount removed:

```
[ERROR nethsm_pkcs11::api] NetHSM PKCS#11: Failed to initialize configuration: Failed to load config
Error configuring seal "pkcs11": failed to initialize PKCS11: pkcs11: 0x6: CKR_FUNCTION_FAILED

$ kubectl -n nethsm-lab describe pod openbao-lab-0 | sed -n '/Mounts:/,/Conditions:/p' | grep nitrokey
(nothing)
```

CKR_FUNCTION_FAILED is the least specific message PKCS#11 has. The line above it, from the library, is the one that counts – and describe pod shows what is really mounted, not what the values say.

Step 3 – Does the library see a slot?

```
$ pkcs11-tool --module /usr/lib/nitrokey/libnethsm_pkcs11.so -L
Slot 0 (0x0): NetHSM
  token label      : LabHSM
  token flags      : login required, rng, token initialized, PIN initialized
```

And with danger_insecure_cert: false against the test container's self-signed certificate:

```
[WARN nethsm_pkcs11::backend::login] Connection attempt 1 failed: IO error connecting to the instance, io: invalid peer certificate: UnknownIssuer
```

That is the error you **want** in production – and then fix with the appliance's CA certificate in the library configuration, not with the danger_switch.

Step 4 – Can the token do what OpenBao needs?

```
$ pkcs11-tool --module ... -M | grep -E 'AES-GCM|OAEP'
RSA-PKCS-OAEP, keySize={1024,8192}, hw, sign
```

No AES-GCM, as with the stick. RSA-OAEP is there; mechanism = "CKM_RSA_PKCS_OAEP".

Step 5 – Login and key

The first initialisation of OpenBao failed – not on the network, not on the PIN:

```
$ bao operator init -recovery-shares=5 -recovery-threshold=3
Error initializing: ... failed to store keys: failed to encrypt keys for storage: no key found
```

```
$ pkcs11-tool --module ... --login -0
Public Key Object; RSA 2048 bits
  label:
  ID:      6f70656e62616f2d756e7365616c
Private Key Object; RSA
  label:
  ID:      6f70656e62616f2d756e7365616c
  Usage:    decrypt, sign
  Access:    sensitive, always sensitive, never extractable
```

The label is **empty**. nethsm-pkcs11 maps the NetHSM key id to CKA_ID – as the hex of the string: 6f70656e62616f2d756e7365616c is openbao-unseal. key_label = "openbao-unseal" can never match. The stanza needs key_id = "0x6f70656e62616f2d756e7365616c". The same lesson as in Part III, a different library: what an object is called is decided by the library, not by the docs.

The failure had a side effect that is in no runbook: OpenBao was **half initialised** afterwards – Initialized true, Sealed true, Total Recovery Shares 0. The barrier had been created, the keys never stored. There is no init and no unseal out of that state; the Raft store had to go (delete the PVC, reinstall the chart). In production that means: init against an HSM only once steps 1 to 6 are green.

Then the wrong PIN – WrongPassphrase in the Secret:

```
[ERROR nethsm_pkcs11::backend::login] Login check failed: Api(ResponseError(ResponseContent { status: 401, content: "" })))
[ERROR nethsm_pkcs11::backend] Username not configured for this user
[WARN nethsm_pkcs11::api::token] C_Login failed with error UserTypeInvalid
Error configuring seal "pkcs11": failed to login: pkcs11: 0x103: CKR_USER_TYPE_INVALID
```

OpenBao says CKR_USER_TYPE_INVALID. Not CKR_PIN_INCORRECT. Whoever only reads the return value looks for a wrong user type. The truth is two lines up (401) and in the HSM's log:

```
[http.access] request GET /api/v1/users/operator
[http.access] response 401 response time 3.632ms
```

Step 6 – One operation

```
$ pkcs11-tool --module ... --login --encrypt --id 6f70... -m RSA-PKCS-OAEP --hash-algorithm SHA256 -i /tmp/plain -o /tmp/enc
Using encrypt algorithm RSA-PKCS-OAEP
$ wc -c /tmp/enc
0
```

Zero bytes: nethsm-pkcs11 does not implement C_Encrypt. That is not a fault of the HSM – OpenBao encrypts in software with the public key anyway and only has the HSM *decrypt*. The signature as a substitute:

```
$ pkcs11-tool --module ... --login --sign --id 6f70... -m SHA256-RSA-PKCS -i /tmp/d -o /tmp/sig
[ERROR nethsm_pkcs11::backend] The mechanism RsaPkcs(Some(Sha256)) not supported for PrivateKey openbao-unseal
error: PKCS11 function C_SignInit failed: rv = CKR_MECHANISM_INVALID (0x70)

$ curl -k -u operator:... https://nethsm:8443/api/v1/keys/openbao-unseal
{"mechanisms":["RSA_Decryption_OAEP_SHA256"],"type":"RSA","operations":5,...}
```

The **usage mask**: the key may do exactly one thing, OAEP decryption. CKR_MECHANISM_INVALID on signing is therefore correct, not broken – and the API even counts how often it has been used. The proof that the operation works is the unseal itself (step 7).

Step 7 – What the HSM itself says

After the fix from step 5, init again, then the pod deleted:

```
$ kubectl -n nethsm-lab logs openbao-lab-0 | grep unseal
core: stored unseal keys supported, attempting fetch
core: vault is unsealed
core: unsealed with stored key

$ kubectl -n nethsm-lab logs deploy/nethsm | grep -v health | tail -2
[http.access] request POST /api/v1/keys/openbao-unseal/decrypt
[http.access] response 200 response time 5.606ms
```

235 milliseconds from attempting fetch to unsealed, and on the other side a line that says which key was used for what. No client log is that unambiguous. On Securosys it is the partition's audit log, on Luna the device's syslog – the timestamp of the last pod start is the search term.

Step 8 – Hold the stanza against what you found

Only now, and the **rendered** one:

```
kubectl -n nethsm-lab exec openbao-lab-0 -- cat /openbao/config/extraconfig-from-values.hcl
kubectl -n nethsm-lab exec openbao-lab-0 -- sh -c 'env | grep -E "^BA0_HSM_" | sed "s/=.*/*=<set>/'
```

lib = what ldd resolves, token_label = step 3, key_id = step 5, mechanism = step 4, BA0_HSM_PIN set and no pin with a different value in the stanza – the environment variable wins.

Step 9 – Mounts and Secrets

```
kubectl -n nethsm-lab describe pod openbao-lab-0 | sed -n '/Mounts:/,/Conditions:/p'
kubectl -n nethsm-lab get secret openbao-hsm -o json | python3 -c "...len..." # Part IV
```

What describe shows is the truth; what the values say is the intent (step 2 showed the difference).

Step 10 – Now the OpenBao logs

```
kubectl -n nethsm-lab logs openbao-lab-0 --previous | grep -iE 'seal|pkcs|error'
```

With 1–9 in mind they are readable: failed to find token was layer 1 (endpoints) or 2 (configuration), CKR_USER_TYPE_INVALID was the PIN, no key found was the label, CKR_FUNCTION_FAILED the missing file.

Step 11 – From the node yes, from the pod no

A default-deny egress policy on the OpenBao pods, three states, three different symptoms:

Policy allows	Library reports
nothing	I/O error ... failed to lookup address information: Try again
DNS only (53 → kube-system)	I/O error ... timeout: global
DNS + 8443 → app: nethsm	core: vault is unsealed

The first symptom looks like a DNS problem and is none: an egress policy without a DNS rule kills name resolution first. And the debug pod – a different label, not covered by the policy – reached the NetHSM the whole time. “From one pod yes, from the other no” is almost always a policy.

```
kubectl -n nethsm-lab get networkpolicy
kubectl -n nethsm-lab describe networkpolicy default-deny-egress
```

Step 12 – strace, and what it does not show this time

The plan was: `kubectl debug` with an Alpine container, `apk add strace`, attach to bao. I learned three things about ephemeral containers on the way:

1. They **inherit the pod's NetworkPolicy**. `apk add` hung because only DNS and 8443 were allowed. An image that already has strace (nicolaka/netshoot) solves it – the node pulls that, not the pod.
2. They run with the pod's securityContext – UID 100, no capabilities. `ptrace` needs root and `SYS_PTRACE`: `--custom debug-profile.json` with `runAsUser: 0` and `capabilities.add: [SYS_PTRACE]`.
3. bao is not PID 1. PID 1 is the chart's shell, PID 12 dumb-init, and PID 13 is called `ld-musl-x86_64`. – the HSM image starts the glibc-built binary via `ld-linux-x86-64.so.2 --preload libgcompat.so.0`. `pgrep -f 'argv0 bao'` finds it.

```
$ strace -f -e trace=openat,connect -p 13
strace: Process 13 attached with 12 threads
(nothing)
```

And then nothing. The library keeps the HTTPS connection open (`max_idle_connection`) – a `bao operator seal` and the `unseal` afterwards create no new `connect()`, and the configuration file was read at start. `strace` answers the questions “which file, which port” only if you attach it **before** the start – in a pod, practically only via a wrapper script in the image. What always works in the shared network namespace:

```
$ ss -tnp | grep 8443
ESTAB 0 0 10.42.4.134:37846 10.43.87.221:8443 users:(("ld-musl-x86_64.",pid=13,fd=8))
```

The process, the socket, the peer. For most questions from step 1 that is enough.

Proven on the side: recovery keys open after a manual seal

The lab was initialised with `bao operator init` **against an HSM** – the way Part V did not go:

```
$ bao operator init -recovery-shares=5 -recovery-threshold=3 -format=json
{"unseal_keys_b64": [],
 "recovery_keys_b64": [ ... 5 ... ],
```

No unseal keys, five recovery keys, and OpenBao was Sealed `false` without further ado. And the claim from Part VII, tried out:

```
$ BAO_TOKEN=... bao operator seal
Success! Vault is sealed.
$ bao operator unseal <recovery key 1>    Unseal Progress 1/3
$ bao operator unseal <recovery key 2>    Unseal Progress 2/3
$ bao operator unseal <recovery key 3>    Sealed false
```

Three times `POST /api/v1/keys/openbao-unseal/decrypt` in the NetHSM log. The keys authorised, the HSM decrypted – without the HSM the three entries would have gone nowhere.

The order, as a table

#	Layer	Command	Found here
1	network	nslookup, wget/nc from the pod, get endpoints	Service without endpoints (probe on 412); SNI
2	library	ldd, file, describe pod	ConfigMap mount missing → CKR_FUNCTION_FAILED
3	slot	--list-slots	invalid peer certificate: UnknownIssuer
4	mechanism	--list-mechanisms	no AES-GCM; OAEP present
5	login/key	--login -0	empty label, ID = hex → key_id; 401 as CKR_USER_TYPE_INVALID
6	operation	--sign, HSM API	usage mask: OAEP decrypt only
7	HSM log	appliance	POST .../decrypt 200
8	stanza	rendered HCL + env	key_label → key_id
9	pod	describe pod, Secret length	–
10	OpenBao	logs --previous	now readable
11	policy	networkpolicy	three symptoms, one cause
12	syscalls	strace, ss -tnp	warm connection: ss instead of strace

And the rule that holds all twelve together: **after every error found, start again at step 1**. Four of the six failures in this part had the same error message in OpenBao (failed to find token) and four different causes.

What the lab does not prove

A test container is not a device. Not checked: TLS with a real CA certificate instead of `danger_insecure_cert`; failed-attempt counters and lockouts – the NetHSM has no visible one, real appliances lock users after a few attempts; high availability with several instances in the library configuration; and the logs of Primus or Luna, which look different but say the same.

Part IX – One HSM for all pods: the HSM VM (draft)

This part is not implemented. It describes what the next step would be and weighs the options.

The problem with the setup from Part IV: the stick hangs off one worker, so OpenBao hangs off one worker. An HA OpenBao with three replicas is not possible that way – three pods on three nodes would need three sticks with the same key (DKEK!) or an HSM that is reachable over the network. The goal: a dedicated VM holds the stick and makes it available to all OpenBao pods. Four ways, from the simplest to the proper one:

Way A – Transit seal via the VM OpenBao (recommended)

That was the original plan for N° 6, and after this guide it is more attractive than before. The OpenBao on the VM from N° 3 gets the stick and seal "pkcs11" – exactly as here, only as a systemd service instead of a pod, without protocol mismatch (client and daemon from the same Ubuntu), without nodeSelector, without hostPath. The cluster OpenBao then gets no PKCS#11 seal but a **transit seal**: it has its root key encrypted by the VM OpenBao via its transit engine.

```
Cluster pods (any number, any nodes)
  seal "transit" { address = "https://bao-vm:8200", key_name = "cluster-unseal", ... }
    | HTTPS, token with a policy only on transit/*/cluster-unseal
    ▼
VM OpenBao — seal "pkcs11" — pcsd — Nitrokey HSM 2
```

Advantages: no PKCS#11 in the cluster, no custom image, HA with three replicas possible immediately, the prepared files `cluster/transit-setup.sh` and `cluster/values-transit.yaml` fit. Disadvantage: a chain – the cluster hangs off the VM, the VM off the stick. If the VM fails, no cluster pod restarts any more; if it is **running**, it keeps running. The transit token needs rotation (periodic token, N° 3 has the pattern).

Way B – p11-kit remote: the PKCS#11 library over the network

p11-kit can export a PKCS#11 module over a Unix socket:

```
# on the HSM VM
p11-kit server --provider /usr/lib/x86_64-linux-gnu/opensc-pkcs11.so \
  "pkcs11:manufacturer=www.CardContact.de" -n /run/p11-kit/hsm.sock
```

In the pod, OpenBao loads the file `p11-kit-client.so` instead of `opensc-pkcs11.so` and gets `P11_KIT_SERVER_ADDRESS=unix:path=/run/p11-kit/hsm.sock` – where the socket in the pod comes from a sidecar that tunnels it to the VM (ssh -L, socat with TLS, or a WireGuard network). p11-kit itself has **no authentication and no encryption**; the PIN travels through this channel. The tunnel is mandatory, not optional.

Advantage: OpenBao keeps seal "pkcs11", the VM is a dumb PKCS#11 server without state of its own. Disadvantage: a sidecar per pod, a tunnel that has to be up before OpenBao, and p11-kit in the image – with the same pcsc-lite question on the VM side. Not tested.

Way C – USB/IP

The Linux kernel can export USB devices over IP (usbip). The HSM VM exports the stick, a worker imports it and sees it as a local device. That moves the stick from one worker to another but does not make it available to **all** pods at once – a USB device has one host. Usable for failover, not for HA. And USB/IP over an untrusted network is an unencrypted USB bus over an untrusted network.

Way D – Nitrokey NetHSM

Nitrokey's answer to exactly this question: an HSM with a REST API, its own PKCS#11 library (libnethsm_pkcs11.so, for glibc and musl), clustering, backup and an official OpenBao guide. There too RSA-OAEP applies (no AES-GCM), there too a custom image on an openbao-hsm base. There is a container test image for the rehearsal. The price is that of an appliance; for a lab it is the answer to "how do the big ones do it", not to "what do I build next week".

Recommendation

Way A. It uses what is there (VM OpenBao, Ansible role, prepared scripts), it brings HA for the cluster, and it keeps PKCS#11 in one place where it is simple. The stick moves from worker-03 to the VM (qm set), the cluster OpenBao migrates from pkcs11 to transit – an auto-seal-to-auto-seal migration for which OpenBao provides disabled = "true" on the old stanza. That will be N° 6b or an addendum to this guide.

Part X – OpenBao 2.7: from HSM build to KMS plugin (draft)

This part is not implemented either; 2.7.0 is in beta at the time of writing.

The first start of the HSM image had a warning in the log worth reading:

```
[WARN] The HSM distribution of OpenBao is discontinued and will no longer
receive updates beyond this minor version. PKCS#11 support has not been
removed, but is now available via an external KMS plugin that is drop-in
compatible with the previously built-in PKCS#11 seal.
```

openbao/openbao-hsm ends with 2.6.x. From 2.7 there is one standard image and a **KMS plugin mechanism**: auto seals that are no longer built in run as a separate process that OpenBao starts. The configuration gets one more stanza, the seal stanza stays:

```
plugin "kms" "pkcs11" {
  command = "openbao-plugin-kms-pkcs11"
  version = "v0.2.0"
}

seal "pkcs11" {
  lib      = "/usr/lib/pkcs11/opensc-pkcs11.so"
  token_label = "SmartCard-HSM"
  key_label  = "openbao-unseal"
  mechanism  = "CKM_RSA_PKCS_OAEP"
}
```

The name in seal must be the name from plugin. kms plugins can **only** be registered declaratively, not via the API – they have to be there before OpenBao is unsealed. The binary lies in plugin_directory; alternatively OpenBao pulls it as an OCI artifact (image = "...@sha256:...").

The stumbling blocks already visible

The plugin release (openbao-plugins, kms-pkcs11-v0.2.0, September 2026) ships openbao-plugin-kms-pkcs11_linux_amd64_v1 – a **glibc** binary (interpreter /lib64/ld-linux-x86-64.so.2). On the Alpine standard image (musl) it does not run without gcompat. The clean way is the UBI variant:

```
FROM openbao/openbao-ubi:2.7.x
USER root
RUN microdnf install -y opensc pcsc-lite-libs && microdnf clean all
COPY --chmod=0755 openbao-plugin-kms-pkcs11_linux_amd64_v1 /openbao/plugins/openbao-plugin-kms-pkcs11
USER openbao
```

Things to check about that as soon as 2.7.0 is out:

- **RHEL 9 ships pcsc-lite 1.9.x** – protocol 4:4. The pin from Part III would become unnecessary; the host's pcscd 2.0.3 fits.

- **OpenSC 0.23 in RHEL 9** – the token label will be SmartCard-HSM (UserPIN) again. Check after the rebuild, as always.
- `plugin_directory` in the server configuration has to point at the directory; the chart has `server.standalone.config` for that and – if needed – an `extraVolumes/volumes` mount for the plugin binaries.

The migration itself is meant to do without `unseal -migrate`: the plugin is “drop-in compatible” according to the release notes, the root key stays wrapped with the same HSM key. One would still test it in the kind context first – with a snapshot beforehand.

Appendix A – All commands

```
# — Proxmox host —————
lsusb | grep -i nitrokey
qm set <vmid> -usb0 host=20a0:4230
qm shutdown <vmid> && qm start <vmid>

# — Worker VM —————
sudo apt install -y pcscd libccid pcsc-tools opensc
sudo systemctl enable --now pcscd
sudo vi /etc/polkit-1/rules.d/40-allow-pcscd.rules          # see Part II
sudo systemctl restart polkit pcscd
pcsc_scan
sc-hsm-tool                                               # status, DKEK, PIN tries
sc-hsm-tool --initialize --dkek-shares 1 --label openbao # ONLY on a fresh stick
sc-hsm-tool --create-dkek-share dkek-share-1.pbe
sc-hsm-tool --import-dkek-share dkek-share-1.pbe
pkcs11-tool -M | grep -E 'AES|OAEP'                     # what the token can do
pkcs11-tool --login --keypairgen --key-type rsa:2048 --label openbao-unseal --id 10 --usage-decrypt
pkcs11-tool -0                                           # public part
sudo journalctl -u pcscd --since -15min                  # protocol mismatch?

# — Image —————
docker buildx build --platform linux/amd64,linux/arm64 -t softxpert/openbao-pkcs11:2.6.2 --push .
docker buildx imagetools inspect softxpert/openbao-pkcs11:2.6.2 # digest → values
trivy image --platform linux/amd64 --severity HIGH,CRITICAL softxpert/openbao-pkcs11:2.6.2

# — Cluster: preparation —————
kubectl apply -f pkcs11-debug.yaml                        # Part IV
kubectl -n openbao exec pkcs11-debug -- pkcs11-tool -L   # label from THIS image
read -rs "PIN?HSM user PIN: "; printf '%s' "$PIN" > /tmp/hsm-pin; unset PIN
kubectl -n openbao create secret generic openbao-hsm --from-file=BAO_HSM_PIN=/tmp/hsm-pin
rm -P /tmp/hsm-pin
kubectl -n openbao get secret openbao-hsm -o json | python3 -c "...len..." # 6–15 bytes!

# — Cluster: migration —————
kubectl -n openbao exec -it openbao-0 -- bao operator raft snapshot save /tmp/pre-pkcs11.snap
kubectl -n openbao cp openbao-0:/tmp/pre-pkcs11.snap ./pre-pkcs11.snap
helm upgrade openbao openbao/openbao --version 0.29.4 -n openbao -f helm/values.yaml
kubectl -n openbao delete pod openbao-0
kubectl -n openbao logs openbao-0 | grep -iE 'seal|error'
kubectl -n openbao exec -it openbao-0 -- bao operator unseal -migrate # x3, ONCE
kubectl -n openbao exec openbao-0 -- bao status

# — The proof —————
kubectl -n openbao delete pod openbao-0                 # enter nothing
kubectl -n openbao logs openbao-0 | grep unseal         # "unsealed with stored key"

# — Rotate the recovery keys (not carried out) —————
kubectl -n openbao exec -it openbao-0 -- bao operator rekey -target=recovery -init -key-shares=5 -key-threshold=3
kubectl -n openbao exec -it openbao-0 -- bao operator rekey -target=recovery -nonce=<nonce>
> # x3 OLD keys → 5 NEW

# — The way back (not carried out) —————
```

```
# seal "pkcs11" { ... disabled = "true" } → helm upgrade → delete pod
kubectl -n openbao exec -it openbao-0 -- bao operator unseal -migrate # x3 RECOVERY keys
```

Appendix B – Glossary

Seal / barrier – The barrier is OpenBao's encryption layer over the storage; the seal determines how the root key for it is protected: Shamir (enter keys) or auto seal (ask an external system).

Root key – Key with which OpenBao encrypts the storage. Lies encrypted in storage itself – with pkcs11, with an AES key that is RSA-OAEP-wrapped.

Recovery keys – The former unseal keys after a migration to auto seal. Authorise generate-root and the way back; cannot reconstruct the root key.

HSM – Hardware security module: generates, stores and uses keys without handing them out.

Nitrokey HSM 2 / SmartCard-HSM – USB stick with a SmartCard-HSM card from CardContact; OpenSC support, RSA/ECC, no AES-GCM.

PKCS#11 (Cryptoki) – Standard C API for HSMs and smartcards; a .so loaded via dlopen.

Slot / token / object – Socket / card in the socket / key or certificate on the card. Tokens have a label; the SmartCard-HSM's label is generated by OpenSC and changes between versions.

Mechanism – A cryptographic operation the token performs (CKM_RSA_PKCS_OAEP, CKM_AES_GCM). pkcs11-tool -M lists them.

User PIN / SO PIN – Login for key operations (3 tries) / administrative login for initialisation and PIN reset (15 tries).

DKEK – Device Key Encryption Key of the SmartCard-HSM. Only with a DKEK share can keys be exported encrypted and brought to a second stick. Set at --initialize.

OpenSC – Open-source implementation of PKCS#11 for smartcards; provides opensc-pkcs11.so, pkcs11-tool, sc-hsm-tool.

PC/SC, pcscd, libpcsc-lite – The reader abstraction below PKCS#11. pcscd is the daemon (speaks CCID/USB), libpcsc-lite the client library; both speak a versioned protocol over /run/pcscd/pcscd.comm. Client 4:5 against server 4:4 is rejected.

CCID – Chip Card Interface Device, the USB protocol for smartcard readers; libccid is the driver in pcscd.

Polkit – Authorisation service on Linux; pcscd asks it whether a process may use the reader.

HSM build (+hsm, cgo) – OpenBao binary with PKCS#11 support compiled in; as openbao/openbao-hsm up to 2.6.x, KMS plugin afterwards.

KMS plugin – From OpenBao 2.6/2.7: auto-seal mechanism as an external process, declared with plugin "kms" "<name>" in the server configuration.

-migrate – Flag of bao operator unseal that re-encrypts the root key from the old to the new seal. Once per migration, with the keys of the **old** seal.

OnDelete – StatefulSet update strategy: a changed template only takes effect when the pod is deleted. Chart default for OpenBao.

Digest pin – Image reference name: tag@sha256:...; the digest wins. Protects against overwritten tags and the node cache.

About the author

Thomas Zachmann is a freelance platform engineer based in Hamburg. He builds enterprise platforms for Kubernetes, cloud and AI workloads – from identity and secrets through CI/CD and GitOps to observability – so that the in-house team can run them without him afterwards. These Field Notes come out of that work. For project enquiries: thomaszachmann.de.

The pod could not find the HSM. The test pod next to it could.

This guide abolishes the unseal ritual from N° 1: afterwards the root key is encrypted with an RSA key that never leaves a Nitrokey HSM 2. The stick hangs off the Kubernetes worker, the pod gets the pcscd socket as a hostPath, a custom image brings OpenBao's HSM build and OpenSC. For readers without HSM experience, Part I explains what seal, token, SO PIN and DKEK mean – and why the last question comes before the first key.

The way there: the official image cannot do PKCS#11; pcsc-lite 2.4 in the container speaks 4:5, pcscd 2.0.3 on the host only 4:4; OpenSC 0.26 names the token differently than 0.23; a read -p in zsh yields an empty Secret. Then unseal -migrate, three times – and a pod that comes up without a key. Two drafts to close: one HSM for all pods, and the plugin path of OpenBao 2.7.

```
-- What the pod says, what the host says
Error configuring seal "pkcs11":
  failed to find token with label: SmartCard-HSM (UserPIN)

$ journalctl -u pcscd
Communication protocol mismatch!
Client protocol is 4:5 # pcsc-lite 2.4, Alpine 3.24
Server protocol is 4:4 # pcscd 2.0.3, Ubuntu 24.04
```



openbao	2.6.2+hsm · chart 0.29.4 · standalone
hsm	Nitrokey HSM 2 · FW 4.1 · RSA-2048 · 0AEP
image	hsm-build · opensc 0.26 · pcsc-lite 2.2.3
host	Ubuntu 24.04 · pcscd 2.0.3 · polkit
seal	pkcs11 · recovery shamir 3/5

44 pages · 10 parts · 2 appendices
Deep dive: **Vault in Practice**
leanpub.com/vault-in-practice
Set in Inter Tight, Inter and JetBrains Mono.
All output is real terminal output.
CC BY 4.0 · share freely · no warranty